Social Engineering Case Study: "Incomplete Profile" Email Phishing Against Employees

Overview

This repository presents a case study on a phishing attack that targets employees through a fake "incomplete employee profile" email. The case explains how the attacker used trust in the HR department and a routine request to make the message look normal, how an employee was caught, and which governance, risk, and compliance (GRC) measures could reduce the risk.

> **Note:** This is a hypothetical case study based on common real-world phishing patterns. All names, companies, and details are fictional.

Background

A mid-sized company with about 300 employees uses an internal employee portal where staff update their personal information, view payslips, and request leave. HR regularly asks employees to keep their profiles up to date.

The company has a basic security policy. Awareness training takes place once a year, and there is no simple way for employees to report suspicious emails.

Problem Description

One morning, many employees received an email that appeared to come from the HR department:

- Subject line: *"Your employee profile is incomplete: update within 48 hours"*
- The message said some required information was missing from the employee's profile
- It warned that late updates could affect payroll or system access
- It included a button labeled "Update Profile Now"

The button led to a fake page that looked like the company's employee portal. The page asked the employee to sign in "to verify identity" and then to enter extra personal details

such as phone number and address.

One employee followed the link and entered her information. The attacker then had her login credentials and personal data.

Observations

Several warning signs were present, but they were easy to miss when working quickly:

- The sender's address looked close to the company domain but was not identical
- A generic greeting ("Dear employee") instead of the person's name
- A short deadline combined with a warning about salary or access
- The link's real destination did not match the company portal address
- The page asked for a password after arriving from an email link
- HR does not normally ask for credentials through email

The message was sent early in the workday, when employees were busy and more likely to act on routine requests.

Why the Employees Were Vulnerable

- Updating a profile is a normal task, so the request felt familiar
- High trust in HR as an internal department
- Worry about payroll or losing access
- Limited training with realistic phishing examples
- No quick way to verify the email or report it
- A belief that suspicious emails always look obviously fake

These factors made employees more likely to click without verifying.

Social Engineering Techniques Identified

Authority

The attacker pretended to be the HR department to gain credibility.

Urgency

A 48-hour deadline pushed employees to act before thinking.

Fear of Loss

The warning about salary or access created pressure and anxiety.

Familiarity

A routine request and a portal that looked identical to the real one made the email feel safe.

Risk Assessment (GRC View)

Risk	Likelihood	Impact	Risk Level
Employee credentials stolen through a fake portal	High	High	**High**
Exposure of employees' personal data	Medium	High	**High**
Unauthorized access to internal systems using stolen accounts	Medium	High	**High**
Loss of trust in HR communications	Medium	Medium	**Medium**

Because personal data is involved, the incident may also raise obligations under the Saudi Personal Data Protection Law (PDPL).

Actions Taken

To reduce risk and contain the incident, the following actions are recommended:

- Reset passwords and end active sessions for affected accounts
- Block the phishing domain and remove the email from all mailboxes
- Review the affected accounts for suspicious activity
- Notify employees with a short warning and clear instructions
- Document the incident and review whether personal data notification is required
- Announce that HR will only request updates through the official portal

---

Challenges Faced

Some employees felt the warning was exaggerated because the email looked like a normal HR message. Others worried that clicking made them look careless, so they delayed reporting. New verification steps were also seen as extra work.

This showed that social engineering affects not only the victims but also how people react to the protective measures that follow.

Lessons Learned

- Social engineering works best when the request looks routine
- Trust in internal departments is a common target
- Pressure and fear of loss reduce skepticism
- Employees need a safe, blame-free way to report mistakes quickly
- Awareness must be treated as a managed risk control, not an annual formality

---

Recommendations

Recommendation	Related Framework Area
Enable multi-factor authentication on all accounts	NCA ECC: Identity and Access Management
Use email protection (SPF, DKIM, DMARC, link scanning, external sender warnings)	NCA ECC: Email Protection
Run regular awareness training and phishing simulations	NCA ECC: Cybersecurity Awareness and Training
Provide a simple "report phishing" option and an incident procedure	NCA ECC: Cybersecurity Incident Management
Define a policy that HR requests go through the official portal only	ISO 27001: Policies and Access Control
Protect and minimize employees' personal data	PDPL

For employees:

- Do not sign in from links in emails; open the portal directly instead
- Check the sender address and the real link destination
- Be careful with deadlines and threats about salary or access
- Report suspicious emails immediately, even after clicking

Control numbers should be checked against the official framework documents before use.

Conclusion

This case study shows how a simple "incomplete profile" email can lead to stolen credentials and exposed personal data. The attack depends on trust, routine, and pressure rather than technical skill. Strong protection combines technical controls, clear policies, and employees who understand how manipulation works.

Author

Aljawharah Almotairi
Information Technology Student | Information Security (GRC)